



G R C T R A I N I N G

PORTFOLIO REPORT

Governance · Risk · Compliance

Submitted to:

CEO
Bluesec Consulting Limited

Prepared by:

Elizabeth Sesebor - Cybersecurity Intern
Bluesec Consulting Limited, Lagos

Training Program:

GRC for Cybersecurity — Full Certification Course

Date:

April 2026

PRESENTATION OVERVIEW

What this report covers

01 Executive Summary & Training Overview

02 What I Learned — Core GRC Modules

03 Effective Governance Model

04 Cybersecurity Risk Management

05 Compliance Management

06 Global & Cybersecurity Frameworks

07 Ethical Governance & Best Practices

08 GRC Tools & Platforms

09 Reporting & Regulatory Tracking Systems

10 Application to Bluesec — My GRC Action Plan

11 Critical Gaps Analysis

12 Compliance Charter

13 Risk Register

14 My Roadmap: Intern → Internal Auditor/Risk Mgr

15 Conclusion & Recommendations

EXECUTIVE SUMMARY

Training overview and key outcomes

As a Cybersecurity Intern at Bluesec Consulting Limited, I was sponsored by management to complete a comprehensive GRC for Cybersecurity training program. This report presents a structured account of the knowledge gained, its relevance to our organization's cybersecurity posture, and a concrete action plan for embedding GRC practices at Bluesec.

7

Core GRC Modules
Completed

5+

Global Frameworks
Studied

10

Risks Identified
in Register

3

Critical Gaps
Found

100%

Committed to
Bluesec GRC

Key Outcomes of This Training:

- ✓ Ability to design and implement an effective GRC framework for a cybersecurity startup
- ✓ Skills to conduct risk assessments, build risk registers, and manage compliance calendars
- ✓ Knowledge of global frameworks: NIST CSF, ISO 27001, COBIT, CIS Controls, GDPR, NDPA
- ✓ Capability to serve as an Internal Auditor or Risk Manager/Analyst at Bluesec
- ✓ Practical tools knowledge: ServiceNow GRC, MetricStream, Archer, OneTrust, Vanta

WHAT I LEARNED — CORE GRC MODULES

Full curriculum overview



Effective Governance Model

Board structures, RACI, policies, tone-at-the-top, accountability frameworks



Cybersecurity Risk Management

Risk identification, FAIR model, threat modeling, risk scoring, treatment plans



Compliance Management

Regulatory mapping, compliance calendars, audit management, evidence collection



Global & Cyber Frameworks

NIST CSF, ISO 27001, COBIT, CIS Controls, GDPR, Nigeria NDPA, PCI-DSS



Ethical Governance & Best Practices

Data ethics, whistleblower policies, responsible disclosure, AI governance



GRC Tools & Platforms

ServiceNow, Archer RSA, MetricStream, OneTrust, Vanta — hands-on walkthroughs



Reporting & Regulatory Tracking

KRI dashboards, board reporting, regulatory change monitoring, audit trails

EFFECTIVE GOVERNANCE MODEL

Module 1 — What I learned and how it applies to Bluesec

GOVERNANCE STRUCTURE

Clear accountability from Board → Management → Operations. RACI matrices assign Responsible, Accountable, Consulted, Informed roles for every GRC process.

POLICIES & PROCEDURES

A hierarchy of policies (Information Security Policy → Standards → Procedures → Guidelines) ensures every team member knows expected behaviors.

OVERSIGHT & ACCOUNTABILITY

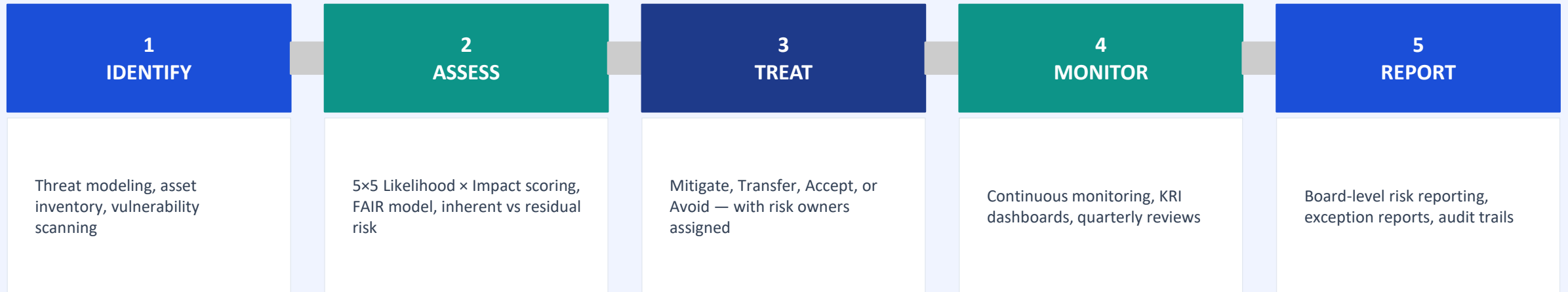
Tone-at-the-top, governance committees, Board reporting, and KPI tracking ensure leaders remain engaged in cybersecurity decisions.

How I Will Apply This at Bluesec:

- ✓ Draft and present a formal Information Security Policy document for CEO/founder approval
- ✓ Propose a GRC governance structure with defined roles: Risk Owner, Compliance Officer, Internal Auditor
- ✓ Develop a RACI matrix for all cybersecurity processes at Bluesec
- ✓ Establish a monthly GRC review meeting cadence with management

CYBERSECURITY RISK MANAGEMENT

Module 2 — Identification, Assessment & Treatment



Risk Scoring Matrix — 5×5 Framework Learned:

IMPACT →	1-Minor	2-Moderate	3-Significant	4-Major	5-Catastrophic
5-Almost Certain	5 MEDIUM	10 HIGH	15 CRITICAL	20 CRITICAL	25 CRITICAL
4-Likely	4 LOW	8 MEDIUM	12 HIGH	16 CRITICAL	20 CRITICAL
3-Possible	3 LOW	6 MEDIUM	9 HIGH	12 HIGH	15 CRITICAL
2-Unlikely	2 LOW	4 LOW	6 MEDIUM	8 MEDIUM	10 HIGH

Key Risk Concepts Mastered

- › FAIR (Factor Analysis of Information Risk)
- › Inherent vs. Residual Risk
- › Threat Modeling (STRIDE, PASTA)
- › Risk Appetite & Tolerance
- › Risk Treatment Plans & Owners
- › KRI — Key Risk Indicators
- › Third-Party Risk Management
- › Continuous Control Monitoring

COMPLIANCE MANAGEMENT

Module 3 — Building a culture of regulatory adherence



Compliance Mapping

Mapping business processes against regulatory requirements (NDPA, GDPR, ISO 27001) to identify obligations and gaps.



Compliance Calendar

Tracking deadlines for regulatory filings, audits, certifications renewals, and policy reviews.



Audit Management

Planning, executing, and reporting internal and external audits with evidence collection and remediation tracking.



Evidence Management

Collecting, storing, and organizing audit evidence (logs, policies, screenshots) for regulatory reviews.



Control Testing

Testing the design and operating effectiveness of controls through walkthroughs, sampling, and observation.



Compliance Reporting

Producing dashboards and reports showing compliance posture, open findings, and remediation progress to management.

Bluesec Application: I will build a Compliance Register mapping all applicable Nigerian and international regulations, assign owners, and maintain a rolling 12-month compliance calendar.

GLOBAL & CYBERSECURITY GOVERNANCE FRAMEWORKS

Module 4 — Understanding the landscape of standards and regulations

NIST CSF 2.0

GOVERN · IDENTIFY · PROTECT · DETECT · RESPOND · RECOVER

Primary cybersecurity risk management framework — voluntary, risk-based, widely adopted.

ISO/IEC 27001:2022

Information Security Management System (ISMS)

International standard for establishing, implementing, and maintaining an ISMS. Certifiable.

COBIT 2019

Control Objectives for IT and Related Technologies

IT governance framework aligning IT strategy with business objectives. Key for audit.

CIS Controls v8

18 Critical Security Controls

Prioritized set of actions to protect against cyber threats — ideal for startups like Bluesec.

Nigeria NDPA 2023

Nigeria Data Protection Act

Nigeria's primary data protection law — binding on all entities processing Nigerian data.

GDPR

EU General Data Protection Regulation

Applies to Nigerian tech firms with EU clients. Heavy fines for non-compliance.

PCI-DSS v4.0

Payment Card Industry Data Security Standard

Required if Bluesec or clients handle cardholder data.

SOC 2 Type II

Service Organization Control 2

Trust Services Criteria — critical for SaaS/cloud services. Builds client trust.

ETHICAL GOVERNANCE & GRC TOOLS

Modules 5 & 6 — Best practices and platform knowledge

Ethical Governance & Best Practices



Data Ethics & Privacy

Principles of data minimization, purpose limitation, and consent management in line with NDPA/GDPR.



Responsible Disclosure

Structured vulnerability disclosure programs protecting both researchers and organizations.



Whistleblower Policy

Anonymous reporting channels enabling employees to surface concerns without fear of retaliation.



AI & Algorithmic Governance

Ethical oversight of AI tools — fairness, explainability, bias testing, and human-in-the-loop controls.

GRC Tools & Platforms Studied

ServiceNow GRC

Enterprise-grade IRM platform — policy management, risk registers, compliance workflows, audit management. Ideal for larger organizations.

Archer RSA

Highly configurable GRC platform used in finance and healthcare. Strong audit and regulatory compliance modules with custom dashboards.

MetricStream

Cloud GRC platform with integrated risk, compliance, audit, and vendor management. Popular in regulated industries.

OneTrust

Privacy-focused GRC tool — strong for GDPR/NDPA compliance, consent management, data mapping, and privacy impact assessments.

Vanta

Automated compliance platform ideal for startups. Continuous monitoring for SOC 2, ISO 27001, GDPR. Recommended for Bluesec.

REPORTING & REGULATORY TRACKING SYSTEMS

Module 7 — Communicating risk and compliance posture effectively

What I Learned:

KRI Dashboards

Building Key Risk Indicator dashboards that provide real-time visibility into the organization's risk posture for management.

Board Reporting

Structuring concise, action-oriented cybersecurity and compliance reports for C-suite and Board audiences — translating technical risk into business language.

Regulatory Change Mgmt

Monitoring and tracking regulatory changes (new laws, updated standards) using feeds from regulators, legal counsel, and GRC platform alerts.

Audit Trail Maintenance

Maintaining tamper-evident logs and evidence trails for regulators and auditors — critical for demonstrating compliance.

Sample Board Risk Report Structure

01

Executive Summary

1-page status: Overall risk level (RAG), top 3 risks, compliance score

02

Risk Heatmap

Visual 5×5 matrix showing current risk distribution across categories

03

KRI Status

Key Risk Indicators vs thresholds — green/amber/red traffic light view

04

Compliance Scorecard

Regulatory obligations: % complete, overdue items, upcoming deadlines

05

Open Audit Findings

Count by severity, owner, days-open, target remediation date

06

Recommendations

Top 3 management actions required with business impact justification

Applying training to build a GRC function from the ground up

PHASE 1 — Months 1–2

Foundation Building

- Complete an asset inventory of all IT systems, data, and vendors
- Draft Information Security Policy & Acceptable Use Policy
- Build and present the Bluesec GRC Governance Charter
- Conduct initial risk assessment and populate Risk Register
- Map all applicable regulations (NDPA, GDPR, ISO 27001)

PHASE 2 — Months 3–4

Structure Building

- Establish GRC Committee with monthly review cadence
- Implement a compliance calendar with all regulatory deadlines
- Begin ISO 27001 readiness assessment and gap analysis
- Deploy lightweight GRC tool (Vanta recommended for startup)
- Train all staff on cybersecurity awareness and GRC policies

PHASE 3 — Months 5–6

Maturity Building

- Conduct first full internal audit and produce audit report
- Remediate critical findings from gap analysis
- Produce quarterly GRC dashboard report for management
- Initiate vendor risk assessment for all third-party providers
- Develop incident response and business continuity plans

CRITICAL GAPS ANALYSIS — BLUESEC CONSULTING

Areas requiring immediate attention to build a secure, compliant organization

Gap ID	Severity	Gap Description	Impact	Recommended Action
GAP-01	CRITICAL	No Formal Information Security Policy	No documented ISP exists. Staff have no written guidance on acceptable use, data handling, or security controls.	<i>Draft and approve ISP within 30 days</i>
GAP-02	CRITICAL	No Risk Register or Risk Management Process	Risks are not formally identified, scored, or tracked. The organization is flying blind on its risk exposure.	<i>Implement Risk Register immediately (see Slide 14)</i>
GAP-03	CRITICAL	No NDPA Compliance Program	Nigeria Data Protection Act 2023 is binding. No data mapping, privacy notices, or lawful basis documentation exists.	<i>Appoint DPO; begin NDPA compliance project</i>
GAP-04	HIGH	No Access Control or Privilege Management	No formal RBAC or principle of least privilege in place. Admin access likely shared or undocumented.	<i>Implement RBAC; audit all privileged accounts</i>
GAP-05	HIGH	No Incident Response Plan	No documented process for detecting, containing, or recovering from cybersecurity incidents.	<i>Develop and test an IRP within 60 days</i>
GAP-06	HIGH	No Vendor/Third-Party Risk Management	Third-party tools and vendors are used without formal security assessments or contractual security requirements.	<i>Build vendor risk assessment process</i>
GAP-07	HIGH	No Security Awareness Training Program	Employees have not received formal cybersecurity training. Phishing and social engineering risk is elevated.	<i>Implement quarterly security training</i>
GAP-08	MEDIUM	No Backup & Recovery Procedures	Business-critical data lacks a documented backup, retention, and recovery procedure.	<i>Implement 3-2-1 backup strategy; test recovery</i>
GAP-09	MEDIUM	No Business Continuity Plan	No BCP or disaster recovery plan. A single disruptive event could halt operations indefinitely.	<i>Develop BCP; identify critical processes</i>
GAP-10	MEDIUM	No GRC Tool or Compliance Tracking System	Compliance obligations and audit findings are not tracked systematically. Risk of missed deadlines.	<i>Evaluate and deploy Vanta or similar tool</i>

BLUESEC CONSULTING LIMITED — COMPLIANCE CHARTER

Proposed by the GRC Intern | April 2026 | Version 1.0 — For Management Approval

Purpose

This Compliance Charter establishes the framework for managing regulatory obligations, ethical conduct, and compliance risk at Bluesec Consulting Limited. It defines scope, responsibilities, and the compliance program structure to ensure the organization meets all applicable legal, regulatory, and contractual requirements.

Scope

This Charter applies to all employees, contractors, interns, and third-party vendors acting on behalf of Bluesec Consulting Limited across all services, geographies, and client engagements.

Applicable Regulations

Nigeria Data Protection Act (NDPA) 2023 · Nigeria Cybercrime Act 2015 · ISO/IEC 27001:2022 · GDPR (for EU-related engagements) · PCI-DSS (for payment-related projects) · CBN Cybersecurity Framework (where applicable)

Roles & Responsibilities

Compliance Officer (to be appointed): owns the program | Risk Manager/Internal Auditor: conducts assessments and audits | All Staff: comply with policies, report violations | CEO/Founder: sets tone-at-the-top, approves the Charter

Compliance Obligations

1. Annual compliance risk assessment | 2. Quarterly compliance calendar reviews | 3. Staff training twice per year | 4. Regulatory change monitoring (monthly) | 5. Internal audit at least once per year | 6. Mandatory incident reporting within 72 hours

Compliance Culture

Bluesec is committed to zero-tolerance for deliberate non-compliance. A whistleblower policy and anonymous reporting channel shall be established. No retaliation against good-faith reporters is permitted under any circumstance.

This Charter becomes effective upon approval by the CEO. It shall be reviewed annually and updated to reflect changes in regulations, business model, or risk environment.

BLUESEC RISK REGISTER — CYBERSECURITY GRC

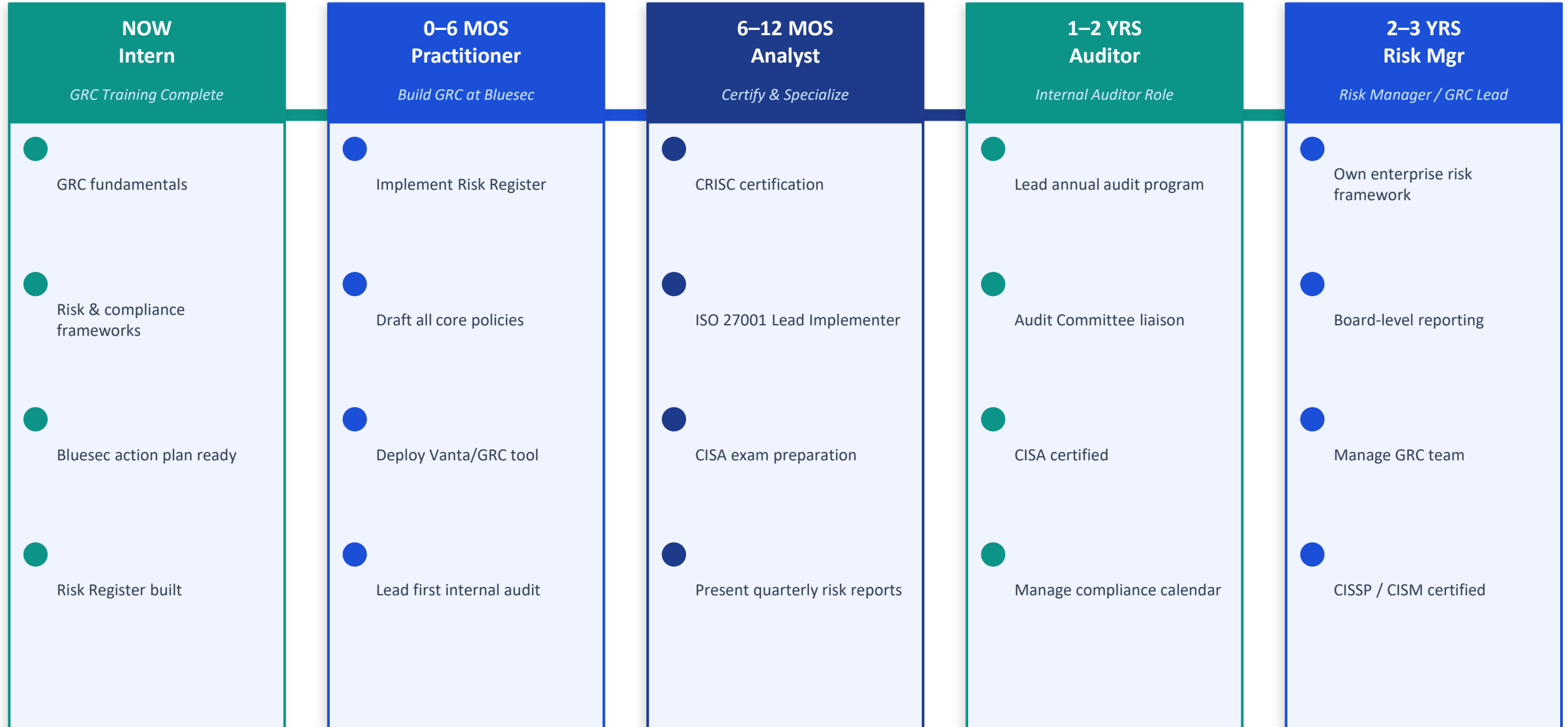
Identified, assessed, and prioritized risks for management action

Risk ID	Category	Risk Description	L	I	Score	Level	Owner	Status
R-01	Cyber	Data breach / unauthorized access to client data	4	5	20	CRITICAL	CISO/Mgmt	● Open
R-02	Cyber	Ransomware attack encrypting company systems	3	5	15	CRITICAL	CISO	● Open
R-03	Cyber	Phishing attack compromising staff credentials	4	4	16	HIGH	CISO/HR	● Open
R-04	Cyber	Insider threat — data exfiltration by employee	3	4	12	HIGH	HR/CISO	● Open
R-05	Compliance	NDPA non-compliance resulting in regulator fines	3	5	15	CRITICAL	Legal/CEO	● Open
R-06	Compliance	No ISO 27001 certification losing enterprise clients	3	4	12	HIGH	CEO	● Open
R-07	Operational	Key person dependency — loss of critical staff	4	4	16	HIGH	HR/CEO	● Open
R-08	Operational	System downtime impacting client service delivery	3	4	12	HIGH	CTO	● Open
R-09	Strategic	Competitor disruption reducing market share	3	4	12	HIGH	CEO	● Open
R-10	Third-Party	Vendor breach exposing client data stored in SaaS tools	3	4	12	HIGH	CISO	● Open
R-11	Financial	Loss of key client / contract resulting in revenue shortfall	3	4	12	HIGH	CEO/Sales	● Open
R-12	HR	Failure to attract/retain cybersecurity talent	4	3	12	MEDIUM	HR	● Open

L = Likelihood (1–5) | I = Impact (1–5) | Score = L × I | Critical: 15–25 | High: 8–14 | Medium: 4–7 | Low: 1–3

MY ROADMAP: INTERN → INTERNAL AUDITOR / RISK MANAGER

Skills, certifications, and milestones to reach my professional goal at Bluesec



Target: Risk Manager / Internal Auditor, Bluesec Consulting Limited — within 2–3 years

CONCLUSION & RECOMMENDATIONS

This GRC training has equipped me with the knowledge, frameworks, and practical skills to contribute meaningfully to Bluesec Consulting's cybersecurity and risk management objectives. I am committed to applying these learnings immediately and growing into the role of Internal Auditor and Risk Manager.

Recommendations to Management:

-  Immediate: Approve this GRC Action Plan and authorize the policy development phase
-  Short-term: Register Bluesec with the Nigeria Data Protection Commission (NDPC) under the NDPA
-  Short-term: Evaluate and deploy Vanta for automated compliance monitoring
-  Medium-term: Support my CRISC and CISA certification pursuit to strengthen Bluesec's GRC capability
-  Ongoing: Establish a formal Risk Committee with monthly reviews using this Risk Register

TRAINING SUMMARY

7 Core Modules Completed

10 Critical Gaps Identified

12 Risks in Register

5+ Frameworks Mastered

3 Phase Action Plan Built